

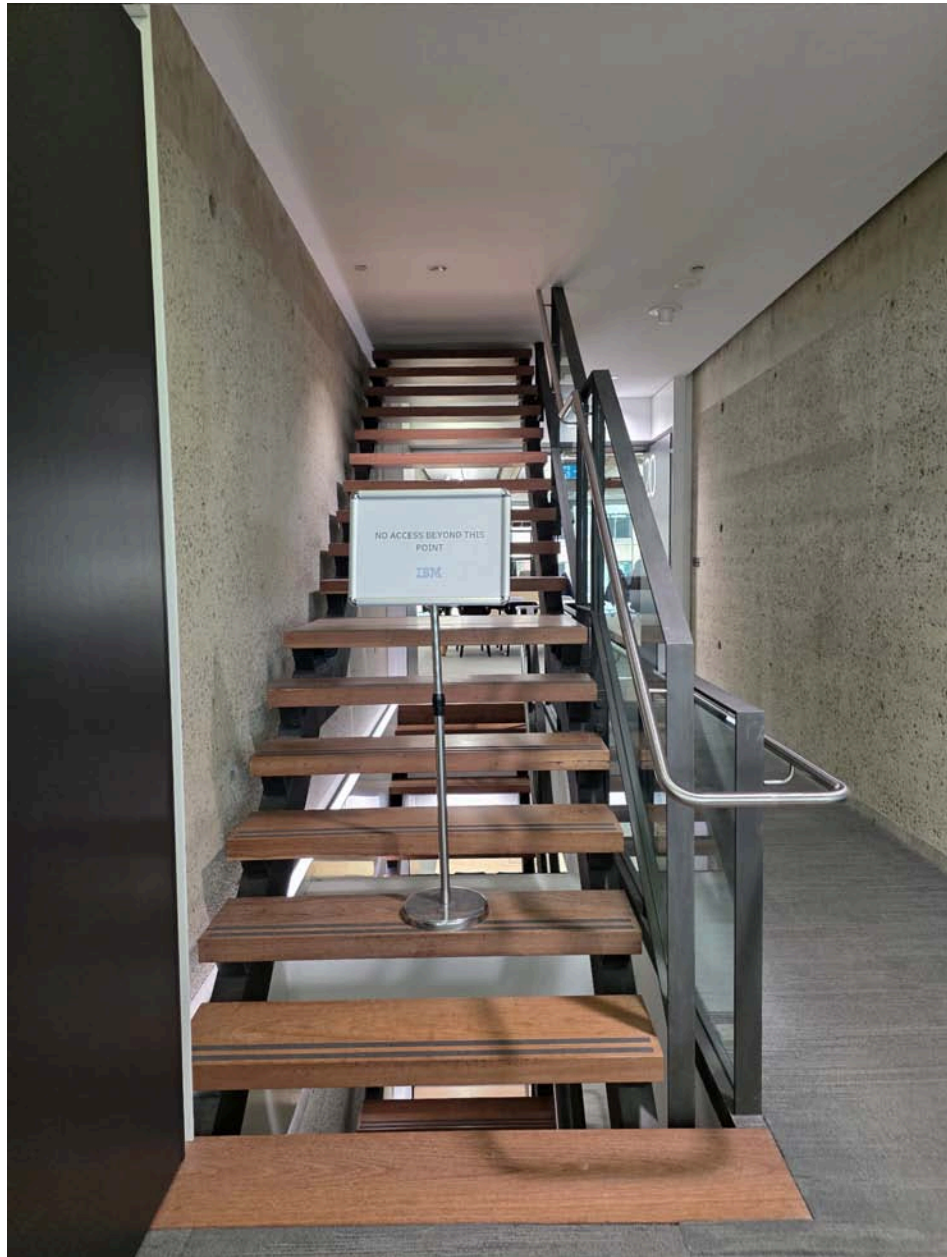
Security Now! #1087 - 07-14-26

HalluSquatting, GhostApproval & GitLost

This week on Security Now!

- Europe warns their largest banks to prepare for AI attack.
- The EU launches an action plan for AI Cybersecurity.
- China considers keeping its budget AI to itself.
- The UK's NCSC & GCHQ announce their "Cyber Shield".
- CISA is using Mythos to audit U.S. government code.
- Microsoft warns of their upcoming patch flood.
- "RoguePlanet" receives an on-the-fly patch.
- An underused mode to kid-proof an iPhone.
- Listener feedback and three new AI attacks.

Some building safety officer may have required the sign... but how could this have happened?



Security News

The European Central Bank warns Europe's big banks to plan for AI cyber threats

Last Tuesday, TheNextWeb picked up the story of the ECB's recent AI warning to Europe's banking industry. They wrote:

The European Central Bank has a warning for the euro area's largest banks. Frontier AI now poses a serious cyber threat, and lenders must draw up plans to counter it. Claudia Buch, the chair of the ECB's supervisory board, wrote to bank chief executives setting a deadline of end-October. Buch asked lenders to patch software faster and harden their AI-enabled cyber defences. She also wants tighter oversight of the outside technology providers they lean on. Over the longer term, banks must modernise ageing infrastructure and sharpen their crisis response. The order carries no fines. Banks that ignore it face no formal sanction. The ECB says it may still use the plans to rank lenders against each other and press the laggards.

One model looms over the letter: Anthropic's Claude Mythos. Anthropic says Mythos can find unknown flaws in IT systems. It claims the model has already spotted thousands of severe vulnerabilities across major operating systems and browsers. The company first limited who could use it, which spread unease across European finance.

Buch put the worry plainly, she wrote: "Emerging models can pinpoint software weaknesses and write working exploits at unprecedented speed. That collapses the gap between finding a flaw and firing through it."

The ECB did not act alone. The same day, the European Systemic Risk Board lifted its assessment of systemic cyber risk to "severe" saying that frontier AI should now count as a source of systemic risk in its own right. The board also flagged a second worry. Nearly all the leading AI providers sit outside the European Union. That leaves the bloc dependent on foreign firms and exposed to geopolitical pressure. It urged Europe to build up its own AI muscle.

The move fits a wider European scramble. ECB President Christine Lagarde warned last month that AI could trigger a dangerous financial crisis. The ECB has already run 109 banks through a severe cyber-attack drill. The threat is not hypothetical either, with state-backed attacks climbing and European bodies such as France's statistics office already hit.

A market has sprung up around the fear. French startup Mistral has opened talks with European banks to sell a flaw-hunting tool. It is one of several firms racing to offer a home-grown answer to Mythos. For now, the regulators sound clear on the danger but are much more vague on the fix. Banks have until October to show they are ready.

This reaction from Europe is not surprising. But given the rapid uptake in the use of AI for cyber attacks, giving banks until October does seem like an overly slow response. But these are banks so it might be as fast as they're able to move.

That other thing that caught my eye was the specific mention of Mythos. You have to give Anthropic credit for the brilliance of their roll-out. The skeptics who cried foul that Mythos was just marketing were not correct, but they certainly had a point. Mythos was able to deliver the goods first, it would have been and would still be truly dangerous in adversarial hands, and Anthropic did take every advantage of that for marketing. We've learned since then that other less powerful models, when carefully orchestrated, can deliver similar results. This was what so

much miffed the guys at AISLE who had actually preceded Mythos with similar results. But they didn't have the presence or the marketing to pull off the coup that Anthropic managed. In time, this will just be a note in the history books.

EU Action Plan on Cybersecurity and Artificial Intelligence

Also last week, the European Union published their so-called "Action Plan on Cybersecurity and Artificial Intelligence. In their announcement of this, the European Commission wrote:

Artificial intelligence is rapidly transforming the cybersecurity landscape. AI can help detect vulnerabilities, prevent cyberattacks and strengthen the protection of critical infrastructure. At the same time, it can also be exploited by malicious actors to automate attacks, identify weaknesses and carry out cyber operations at unprecedented speed and scale.

Building on the EU's existing legal framework on AI and cybersecurity, the Action Plan sets out a coordinated approach to help Member States, businesses and public authorities benefit from the opportunities offered by AI while addressing the new risks it creates. It focuses on three complementary objectives:

- *Promoting the safe and responsible use of advanced AI*
- *Reinforcing the EU's cybersecurity and resilience*
- *Scaling up Europe's AI capabilities for cybersecurity*

To promote the safe use of advanced AI, the Commission will strengthen Europe's capacity to evaluate AI models before they are placed on the EU market, in line with the AI Act. It will also work with the European Union Agency for Cybersecurity (ENISA) to develop a European Blueprint for secure access to advanced AI systems for cybersecurity purposes and establish a secure testing platform to help organisations in critical sectors, such as energy, transport, health, finance and public administration, safely test and deploy AI solutions.

The Action Plan also reinforces the EU's cybersecurity by promoting the implementation of existing EU cybersecurity legislation, including the NIS2 Directive and the Cyber Resilience Act. It encourages organisations to use AI, including open-source models where appropriate, to detect and address vulnerabilities more quickly and improve their ability to prevent and respond to cyberattacks.

To strengthen Europe's technological leadership, the Commission will launch an EU Grand Challenge on AI for cybersecurity, bringing together companies, researchers and other stakeholders to develop innovative AI-powered cybersecurity solutions. The EU will also continue investing in sovereign AI capabilities, building on initiatives such as AI Factories and future Gigafactories, while encouraging private investment to help scale up European AI technologies.

The Action Plan complements the EU's existing legal framework for AI and cybersecurity, including the AI Act, the Cyber Resilience Act, the NIS2 Directive, the Digital Operational Resilience Act (DORA) and the Cyber Solidarity Act. By bringing together EU institutions, Member States, industry, researchers, open-source communities and international partners, it aims to ensure that Europe can harness the benefits of AI while remaining resilient against emerging cybersecurity threats.

It occurs to me that initiatives such as this are another less obvious downstream benefit of the way Anthropic marketed Mythos. Just as it shook up the U.S. Government, in today's highly-connected world, it similarly shook up every other major nation. The EU's announcement reads like bureaucratic boilerplate, but that's what bureaucrats produce. It is also, however, a reflection of what those bureaucrats are thinking. And what they are thinking amounts to *"Holy crap!! We don't want to be left behind!!"* And this brings us to China...

Reuters brings us AI news from China

Reuters headline reads: "Beijing is looking at curbing overseas access to China's top AI models, sources say." They elaborate on this, writing:

Three people familiar with the discussions said that Chinese authorities have held meetings with top tech firms over the past month about potentially restricting overseas access to China's most advanced AI models. The talks follow a number of steps by Beijing to keep homegrown AI within the country and underscore how China, like the U.S., is now treating cutting-edge artificial intelligence as a critical national asset that needs controls. Companies present at the talks included tech giants Alibaba and ByteDance as well as startup Z.ai, said the people, who were not authorised to speak to media and declined to be identified.

Since the emergence of DeepSeek's R1 model last year, Chinese AI models have made big inroads globally thanks to their low costs and increasing capabilities. Any decision by Beijing to limit access to those products could ripple across AI markets as costs for many businesses would likely increase.

At the meetings, led by China's Ministry of Commerce, participants discussed putting limits on the most advanced AI models — both closed-source and more open versions, according to two of the sources. Officials talked about making any leak or theft of proprietary AI technology an offence under China's stringent national security law. The officials also raised the possibility of implementing new measures to restrict who can fund domestic AI startups. The scope of the potential restrictions is still being discussed and may only apply to future models. It was not immediately clear when or even if they would come into force.

China's commerce ministry, which oversees export regulations, and the National Development and Reform Commission — the country's state planning agency whose officials also attended the meetings — did not respond to Reuters requests for comment. Alibaba, ByteDance and Z.ai also did not respond to Reuters queries.

All three companies have a range of AI models, some closed-source while others are open-weight, meaning users can download, run and customize the underlying systems. Alibaba's Qwen and ByteDance's Doubao are two of the most widely used AI models in China. Z.ai has recently set Silicon Valley abuzz as the capabilities of its GLM-5.2 model come close to leading U.S. offerings at a fraction of the cost.

U.S. President Donald Trump's administration has also been deeply concerned about national security implications of AI — in particular the potential for American AI products to be misused by military intelligence in China, Russia and other countries of concern. In June, it ordered that foreign nationals not have access to Anthropic's most advanced Fable and Mythos models, which prompted the company to disable the models for all users globally as nationality could not be verified in real time. Export controls for Fable, which is designed for the general public,

have since been lifted after new safeguards were put in place. But Mythos, designed for cybersecurity professionals, is still only available to some trusted U.S. organisations.

Some U.S. AI experts have also said the U.S. needs to regulate the use of Chinese AI models. According to two of the sources, Chinese authorities are deeply worried about the potential for Mythos to exploit software vulnerabilities and that Washington might deploy the model against Chinese interests. That echoes concerns publicly voiced by state media and Zhou Hongyi, founder of cybersecurity firm 360, a major vendor to government and enterprise clients, who has said China needs to develop its own Mythos.

This year, China has implemented numerous measures to protect homegrown AI. In April, the country's state planner ordered Meta to unwind its \$2 billion acquisition of Chinese-founded AI startup Manus. In early June, authorities issued sweeping new rules, tightening control of overseas deals that involve Chinese investors, technology, data and national security. China had also launched investigations this year into Manus and other local AI startups that had moved abroad, seeking to establish whether they have broken export control laws, according to two of the sources and a third person. Manus has not responded to requests for comment.

Reuters was not able to learn how any potential new restrictions on overseas access to Chinese AI models might work. But some hints might be gleaned from a May roundtable of Chinese legal experts on regulations governing open-source AI. According to a summary of the discussions published in an official Supreme People's Court journal, participants proposed a tiered system: basic open-source tools subject to a simple filing, more advanced technologies facing security reviews, and the most sensitive frontier models barred from public release or restricted to domestic use.

None of that should come as any surprise. But I wanted to share this reporting from Reuters, following news from Europe, to highlight the fact that every major nation is waking up to the fact that what has been happening with AI is not hyped-up marketing and overstatement. I've recently seen the impact of the emergence of AI being compared to the harnessing of electricity. That doesn't feel like an exaggeration to me. The entire world is being turned upside down by the emergence of this new AI technology and I continue to be certain that we're still at just the beginning of this journey.

Our next stop on this grand global tour, examining the impact of AI on cyber security takes us to the United Kingdom where we learn about their just-announced "Cyber Shield" initiative.

The NCSC and GCHQ announce the UK's "Cyber Shield"

The NCSC is the UK's National Cyber Security Center. The NCSC's blog posting last week was titled *"Cyber Shield: The path to an agentic AI future for cyber defence. Why the UK is pioneering an initiative to develop a national scale, sovereign defence capability."* The posting led by quoting Anne Keast-Butler's the director of GCHQ during her recent inaugural GCHQ Annual Lecture at Bletchley Park on May 27th. Anne said:

"We need to reimagine cyber security in the AI world. In the past few months, GCHQ has developed the blueprint for a new national cyber defence capability that will hardwire cutting-edge agentic AI into machine speed cyber defence." The NCSC posting followed that, writing:

The NCSC and the Department for Science, Innovation and Technology (DSIT) are developing this blueprint, which we are calling Cyber Shield. The objective of Cyber Shield is to build a national-scale, collaborative approach to agentic cyber defence, using frontier AI to identify, reduce and resolve our national cyber risk.

In this blog, we set out why we need a new approach to cyber security, and outline our aim and vision for Cyber Shield – as well as the challenges. We also invite debate and engagement from academia, Critical National Infrastructure (CNI) organisations, frontier labs, the cyber defence sector and others to help collectively solve the challenges and develop the blueprint

Why the UK needs a step change in cyber defence: The UK faces a cyber threat that is growing in scale, speed and sophistication. Attacks from hostile states, organised crime and others are increasingly disrupting services, harming businesses and exposing sensitive data. Frontier AI is accelerating this trend, with the potential to shift the balance in favour of attackers – and with serious implications for defenders. We need to keep our critical technology systems secure against both existing and emergent cyber threats.

Today's challenge is that there are many preventable weaknesses. We know that a large proportion of critical systems do not fully meet the aims set out in the Cyber Assessment Framework (CAF). Many attacks still succeed because of basic vulnerabilities, including outdated or unsupported systems, delays in applying security updates, and weak controls over access to systems and data. These are well-understood risks, but they remain widespread, leaving the UK exposed to attacks that are often avoidable. This makes getting cyber security fundamentals in place now more important than ever.

At the same time, the emerging challenge is that AI is changing how attacks are carried out, increasing their scale and speed. AI is already helping attackers to conduct elements of offensive cyber activity, such as vulnerability discovery and reconnaissance at a much greater scale and faster pace. As a result, activities that once took weeks can now take minutes, reducing the time available for defenders to respond, detect and contain them. This increases the likelihood of successful attacks.

Organisations must take urgent tactical action to ensure critical systems are well defended. Act now to strengthen the fundamentals. Fundamental cyber security remains essential and organisations should prioritise:

- rapid patching of vulnerabilities,*
- reducing reliance on legacy systems and*
- adopting secure-by-design technologies.*

Organisations should also start to use AI in cyber defence, to stay ahead of the attacker. This means:

- using agentic AI to identify exposed vulnerabilities autonomously ('blue' team capability),*
- using AI to detect and contain security incidents and*
- working to address the challenge of safely automating mitigation.*

As well as getting their cyber fundamentals in place, organisations must be prepared for the future challenges.

The shift towards full lifecycle automation of attacks: While some stages of a cyber attack can already be automated, we have not yet seen fully autonomous attacks operating across the complete intrusion lifecycle in real-world systems. In practice, the complexity of these environments still requires human judgement and oversight.

However, frontier AI models are likely to become capable of operating across the full lifecycle – from initial access through to actions on objectives. This could allow attackers to move at machine speed and greater scale, reducing opportunities for detection and response. This has the potential to overwhelm traditional defences and increase the risk of advantage shifting towards the attacker.

Developing viable solutions that scale and execute at the pace we need in the modern era is the remit of the Cyber Shield.

The evolution of AI-enabled cyber capabilities: AI-enabled offensive cyber capabilities are developing rapidly, alongside a growing commercial market for such tools. Together, these trends are accelerating the pace and expanding the scale of cyber threats, and enabling more actors to exploit such capabilities. This evolution presents strategic challenges for the UK.

Many advanced defensive capabilities are inherently dual-use, meaning they could be repurposed for offensive or hostile activity. Organisations developing these capabilities must act responsibly. Identifying and fixing vulnerabilities is essential, but not sufficient on its own. Engaging with initiatives such as Cyber Shield will help ensure that these technologies deliver a net benefit to cyber security.

Cyber Shield supports the ambitions of the UK government to build national-scale, AI-powered defensive capabilities that can operate at speed and scale. In the near future, we envision a world where cyber defence is supported by 'red' and 'blue' agents which identify weaknesses in systems ('red') and defend against threats in real time ('blue'). These AI systems would:

- initially identify vulnerabilities and threats at machine speed, before progressing toward automated remediation
- generate and share insight while detecting and containing breaches
- work under the control and authority of their owners across government and non-government institutions
- collaborate seamlessly across organisational boundaries
- contribute to improving the national security of the UK

These agents are enabled by strong foundations of data, identity, reliability, cyber security, and regulatory compliance. Our approach will be: test, iterate and scale. We will initially partner with network defenders across government and critical UK sectors to test and deploy newly-researched capabilities. This will accelerate learning and improve resilience where it will have the greatest impact. Our aim is to transition to commercially-scalable solutions to deliver a level of national resilience which is ready for the future threat.

The UK will pioneer this approach and provide a case study to the world on how to successfully engineer and deliver the future of active cyber defence in the AI era, in a safe and secure manner, consistent with our values and policies. We will need a number of functions to deliver a national-scale, sovereign cyber shield capability, in association or partnership with leading frontier AI capabilities, cyber defence organisations and academia. We recognise that some of these areas present challenges which will need significant progress in research to unlock. The functions include:

1. **Reliable and explainable AI for cyber security**
This means our AI systems can be: used confidently in production environments at scale authorized by system owners to make safe, reliable and significant real-time changes in support of cyber defence, in a predictable manner.

2. Federated agents

Agents will be federated with underpinning trust infrastructure. These agents will:

- run national-level operations on behalf of the country*
- run under the control and authority of individual organisations*
- secure the means to identify, trust and communicate between themselves, to allow co-operation*

Whoa! Did everyone get that? The GCHQ's NCSC is stating that their goal is to have AI agents operating autonomously to run national-level operations on behalf of the country with a secure means to identify, trust and communicate between themselves for co-operation.

I want to make certain everyone understands what a massive leap forward this represents. While we've been futzing around with AI for coding, the UK's intelligence and cyber security people have been establishing their plans to put autonomous AI agents in charge of their nation's cyber security. Even though it's both the correct way of thinking and has already become inevitable, it's still somewhat bracing to imagine that a few years from now this podcast will probably be reporting on the events surrounding AI agents protecting the borders and networks of those nations that had the foresight to get those efforts underway early. Wow!

3. Vulnerability discovery and mitigation:

Harnessing cutting-edge UK research into agentic red/blue team functions, the aim is to develop and demonstrate automated discovery of network vulnerabilities and develop fully automated vulnerability mitigation workflows

This will allow cyber defenders to operate at beyond human scale, helping them keep pace with attacker capability. These functions will be focussed on critical networks but able to operate at national scale.

4. Co-ordinated detection and response:

Building on the red/blue team functions, the aim is to: provide a means for real-time sharing of insights across organisation boundaries and get agents to leverage these insights to detect and contain adversary behaviour.

5. National-level scanning:

This means automated scanning of critical UK IP ranges for exposed vulnerabilities and analysis of aggregated data to understand national level exposure.

6. National-level mitigation:

This means automation of workflows to allow rapid national-scale mitigation, such as automated blocking of known malicious domains and networks.

Working in partnership is vital. The Cyber Shield vision is ambitious and wide-reaching, and faces significant delivery challenges. It cannot be developed and operated by the NCSC or government alone. In addition, there is a clear potential benefit to UK economic growth from nurturing innovation in this domain.

We need to work in partnership across government, and with industry and academia to develop innovative approaches and evidenced solutions from national- to enterprise-scale and with organisational and sector-based network defenders to deploy and integrate agentic

capabilities under their control and authority into their activities. To this end, the NCSC and DSIT are working together to establish effective pathways for partners to come together and contribute. Get involved! We invite all organisations who are interested in partnering to develop the Cyber Shield to contact the NCSC at cybershield@ncsc.gov.uk.

What's missing from this is any sort of timeline. But I'm sure that would be premature. At this juncture it's still somewhat surprising that they're even talking with such ambition even though I'm also certain that they're not wrong. This is where the world's major nations must now head.

We're witnessing the rapid emergence of the realization that AI is as much a national strategic infrastructure asset as a nation's power grid. But the shape this will take is entirely unknown. For example, where will the AI itself reside? It seems clear that no nation would be willing to outsource its AI to another nation. So it will need to be housed inside the nation's own borders. It will also require physical security and probably redundancy since it will become a strategic asset with extreme national security importance.

When I stop to imagine this, it really is science fiction. It's reminiscent of the movie "Colossus: The Forbin Project." There will be some control room somewhere, where the AI is projecting its status and operations on large screens showing the attacks and threats it's fending off. And trained AI whisperers will be sitting at consoles conversing with it in natural language. The master AI will, in turn, have its own agents to which it assigns sub-projects and research responsibilities. And they may, in turn, have sub-agents of their own as needed. And we're not talking pie-in-the-sky speculation here. We're almost certainly describing a future certainty.

CISA is using Mythos to audit government code

Meanwhile, our own CISA has been quietly using Mythos to audit the U.S. government's code. Reuters reports:

Three people familiar with the matter said on Monday that the U.S. cyber defense agency CISA is using Anthropic's AI model Mythos to audit government software in another sign of government enthusiasm for adopting the AI startup's tools even as the company navigates an ongoing standoff with the White House.

The Cybersecurity and Infrastructure Security Agency is using Mythos to scan government code repositories for bugs that could leave the door open for foreign spies and cybercriminals. Anthropic did not respond to questions about the initiative. A CISA representative said last month that he would check to see if there was anything to share about the matter but did not respond to further emails.

The scanning is being done by CISA's Attack Surface Evaluation team, according to one of the sources. The team is a group within CISA that conducts digital security assessments and hacking exercises across government. Two of the sources said the audits had already uncovered a large number of vulnerabilities but did not elaborate. Reuters could not establish exactly how much government code the team had gone through or the nature or severity of the bugs it discovered.

Reuters reporting then recaps the recent rocky road Anthropic has had with the government

which was initially triggered by their flatout refusal, last February, to remove the safeguards from their models that prevented their model's use for guiding autonomous weapons or facilitating domestic surveillance. Regardless, it's great, and hardly surprising, that CISA is deploying Mythos to help shore-up the U.S. government's existing codebase.

Get ready for the Microsoft Patch'Fest

A number of security outlets picked up on a Microsoft blog posting last Thursday which was titled: *"Evolving Windows vulnerability management to meet the speed of AI-powered discovery"*. Apparently, last month's all-time record-breaking patch Tuesday was just the tip of the iceberg, as we would have imagined. The good news is, Microsoft knows that and is acknowledging that, too. Here's what they shared with the world:

Windows has adapted to emerging threats for decades, all while operating at unparalleled scale. It's our responsibility to bring clarity, transparency and sustained investment so customers understand what is happening, what Microsoft is doing and how they can reduce their exposure.

The pace of vulnerability discovery is changing with advances in AI making it possible to find more issues, faster, across more code, with new mechanisms that can accelerate both discovery and analysis. The fastest way to reduce customer exposure is to find issues before attackers can use them.

Hold on a second there. The fastest way to reduce customer exposure – right down to zero – is not to beat the attackers to them, but rather to not ship buggy issue-laden software products in the first place. I acknowledge that there's a huge amount of fixing to do first, to eliminate the thousands of bugs in the software that's already been shipped. But I'm looking forward to the day when not only all existing bugs have been eliminated, but new code comes "pre-sanitized" before it ships. THAT is the target I'm hoping Microsoft has in mind. Anyway, they continue:

Windows is expanding its ability across the platform to find issues earlier, accelerate the engineering work to fix them, strengthen validation and deliver timely, high-quality updates that keep customers protected.

By applying AI across security analysis, we can identify patterns faster, prioritize risk and scale vulnerability discovery across the Windows codebase. This helps reduce the time between discovery and customer protection. It includes using Microsoft Security's multi-model agentic scanning harness (MDASH), which utilizes multiple models including leading third-party AI vulnerability discovery models.

To run MDASH at Windows scale, Windows set up dedicated cloud infrastructure for scanning and proving. A scanner pipeline scans critical binaries and validates candidates using multi-model debate across multiple model families. Confirmed candidates then flow to a separate, Windows-specific prove pipeline that helps eliminate remaining false positives, so only the highest-confidence findings reach the engineering team. This automation helps handle a larger volume of potential vulnerabilities and shortens the review window for new ones, shrinking the attack window for zero-day exploits.

Again, that's great... but let's really focus upon eliminating 0-day exploits as a side effect of simply eliminating all exploits. How about that?!

This effort extends beyond Windows as we work across Microsoft to drive broader adoption of these tools and practices throughout both the company and the wider ecosystem.

Yay team!

We partner closely with AI-powered scanning teams across Microsoft's product divisions, sharing insights, comparing best practices and aligning on key findings. In parallel, we collaborate with the Microsoft Security Response Center (MSRC) to continuously refine the end-to-end process from vulnerability discovery and issue filing to remediation and validation. We also regularly reassess our prioritization and rollout strategy based on lessons learned and feedback gathered through our Chief Information Security Officers' (CISOs) engagements with customers.

What did any of that mean? Did AI write this?

We continue to evolve our internal systems and practices so that vulnerability discovery is not treated as a separate activity, but as part of how we build, review and improve Windows before new features or updates are released.

Ah! Okay! Now we're talking!

As a part of this we are updating our Secure Development Lifecycle (SDL) best practices to ensure our secure-by-design approach explicitly accounts for potential AI-enabled attack techniques and exploit paths. That means using AI to help identify potential issues earlier in the development process, while relying on human expertise to evaluate findings, make risk-based decisions and ensure fixes meet the quality bar customers expect.

That all sounds exactly right. We want AI to be looking over the shoulders of their coders, working to spot their mistakes immediately.

As AI helps defenders discover more issues, customers will see a higher volume of security updates included in each security release.

Exactly right. That's what we want. Let's fix the past and break the cycle of adding new problems that need to be fixed later. AI finally offers that hope.

[A higher volume of security updates] is evidence that defenders are getting better at identifying and addressing issues. Our focus is to effectively utilize these AI tools to support faster protection, stronger engineering systems and more actionable guidance for customers.

Windows is evolving our engineering and validation systems to reduce the time from discovery to protection, with areas where customer risk is greatest. As we build our end-to-end system

from discovery to remediation of vulnerabilities on Windows, we're making the following investments to help ensure that we are not compromising update quality as we gain speed:

- We are integrating AI into our process to compress the path from discovery to a validated fix, helping engineers understand failures faster, propose candidate fixes consistent with the surrounding code, surface related issues elsewhere in the codebase and select the regression tests most likely to be affected by a change.*
- Windows updates undergo validation across a range of testing environments, including the Security Update Validation Program (SUVP) and internal validation designed to help evaluate compatibility, reliability and real-world usage scenarios. This broad validation helps identify functional, application compatibility and quality issues before updates are broadly released.*
- We're also investing in new technology, including Windows-specific tools and agentic harnesses, to enable end-to-end generation and validation of fixes using AI, keeping humans in the loop when it comes to code review.*

That's about the first quarter of the blog post. The balance of the posting was a rehash of the various features and benefits of the Windows update offerings for individuals and enterprises. Our takeaway is that Microsoft, like everyone else on the planet from small software publishers to major nation states, is taking the changes that AI is bringing to the world as seriously as we could hope they would. In the specific case of Microsoft this means dealing with their extensive legacy of existing software while also working to prevent turning new bugs loose. Let's all wish them well. I certainly do.

"RoguePlanet" vulnerability receives a patch

"Nightmare Eclipse"s latest parry to annoy Microsoft in the form of the disclosure of a Windows Defender based Elevation of Privilege which the attacker dubbed "RoguePlanet" was patched last Wednesday. Since the trouble lay in Defender, which Microsoft is by-design able to patch at any time on-the-fly, that has already happened. No need to wait for today's 2nd Tuesday of July.

At this moment, the rogue hacker has discovered and released a series of eight 0-day exploits along with working proofs of concepts, each timed to arrive just as Microsoft has started pushing fixes during Patch Tuesday – which, as I noted is once again, today.

Also recall that several months ago this hacker claimed that he or she would be dropping what they described as a "bone shattering" Windows exploit today, July 14th. However, that early months old boast has been partially walked since the hacker has said that the development of "RoguePlanet" consumed more time than expected. So we may get nothing or we may be something less than the promised "bone shattering" Windows apocalypse Day that was promised.

Also remember that we have previously seen some of "Nightmare's" statements later proven to be a bit over aggrandizing. He or she claimed that the earlier Bitlocker bypass could still function in the presence of an authenticating PIN. That was worrisome back when we didn't know the vulnerability's mechanism. Now that we do, we know that a PIN bypass could never have been

possible – and “Nightmare Eclipse” also **had** to know that. So it wasn’t an allowable mistake; it could only be a deliberate falsehood. Have we seen the last of “Nightmare Eclipse”? Only time will tell... and we may know very soon.

Miscellany for Parents

Turn an iPhone into the perfect Kids Phone

Saturday before last, on the 4th of July, I stumbled upon something so cool for our listeners who have young kids that I needed to share it with everyone. I know that we have many such listeners because many have written to me about Internet filtering options for their homes. Even listeners whose kids have grown may have grandkids, or certainly know of others who care about the welfare of youngsters.

Jeremy White wrote a piece in WIRED titled: *"This Buried Apple Feature Turns an iPhone Into the Perfect Kids' Dumb Phone"* Jeremy's tag

line says: *"Apple built a tool for people with cognitive disabilities, but I accidentally discovered it's also the best kids' phone setup no one is talking about—not even Apple."*



<https://www.wired.com/story/this-buried-apple-feature-turns-an-iphone-into-the-perfect-kids-dumb-phone/>

I've linked to Jeremy's piece with the GRC shortcut: <https://grc.sc/dumb> so everyone can find the article and also easily pass the link on to their friends and family members. The full link is also in the show notes along with a photo of the resulting Apple iPhone that Jeremy's young son now carries and uses. Jeremy explains his discovery, writing:

I have been looking at classic dumb phones for months. Not out of nostalgia—though the first phone I bought with my own money was the Nokia 8210, and I still think about it (launched in October 1999 at Paris Fashion Week, it was then the world's smallest and lightest mobile). But the day I've been dreading has come: It's finally time for my son to get his first phone.

Come September, he will have to walk across town to school on his own. But if he's going to be walking around out in the world without me, then a tracking tag won't cut it. He is far too young to have unfettered access to the internet and social media platforms, but what if he gets lost? A classic Nokia, supplying just texts and calls, won't come to his aid. Maps and satnav require a web connection.

In short, he needs a smartphone that's not a smartphone. As a family deeply embedded in the Apple ecosystem, we first looked to set draconian restrictions on my child's Apple account. But, amazingly, it immediately became obvious that it is impossible to block the use of Safari on iOS. Yes, you can restrict access to the app, but children have quickly found workarounds for such measures, such as asking friends to message them links, which can bypass restrictions when opened.

There are third-party apps such as Dumb Phone for iPhones and the Minimalist Phone app for Android users, but what irks me about these is that they charge you for the privilege of removing access to applications from your phone. Not adding—removing. My head can't fathom the logic of paying for things to be taken away from a phone.

Surely there must be a way to set up an iPhone as the perfect dumb phone for children—one with access to only the apps you deem appropriate, no internet browser, but with all-important tracking and navigation abilities—without having to pay another company to make it work? Well, there is. It's been hiding in the iOS Accessibility menu the whole time. And, inexplicably, it's a feature Apple barely talks about.

It's called Assistive Access. Introduced with iOS 17, Apple designed it for those with cognitive disabilities. If you've never encountered or stumbled across it, it's a distinctive iOS experience: fewer options, more focused features, easier to navigate. The aesthetic is ideal for kids: large, friendly tiles for the apps replace the smaller icons of the "normal" Apple interface.

Here's how you set it up: Head into Settings, tap Accessibility, scroll down to the General section at the very bottom, and tap Assistive Access. Now, tap Set Up Assistive Access, then Continue. It will then ask you to select your preferred appearance: rows or a grid. I suggest choosing a grid. This is how you get those super-large tiles. Now the OS will ask you to select allowed apps—tap the green plus icon next to the apps you want to allow.

Crucially, this is where, unlike with Apple's standard child screen-time restrictions, you can choose to completely block internet browsing by simply not allowing Safari, Chrome, or any other similar app. And, unlike with those screen-time restrictions, if someone texts your child a link, it won't work. Why? Assistive Access is designed to prevent accidental navigation, so the system restricts unexpected web browsing.

Even though Assistive Access on Apple devices allows internet access, it is heavily restricted by design, and it's turned off by default. In this mode, the phone treats any link in a message as plain text, preventing the user from accidentally leaving the simplified interface.

Made for caregivers or trusted supporters, the user must specifically add internet-enabled apps like Messages, Safari, or third-party web apps to the Assistive Access interface. And once you add, say, Messages or Calls, you then choose whether your child can contact or be contacted by everyone, their contacts only, or just selected favorites.

You can even choose to have the keypad or speaker be available in Calls. Want the time displayed on the lock screen? Check that box. Make the mute switch inoperable? Tick. Decide

how notifications appear? That too. The Music app only accesses playlists you preapprove. It's all, well, child's play to put together.

Once you're happy with your kid-appropriate apps, you set a unique four-digit Assistive Access passcode. This lets you turn the simplified OS on and off. To leave Assistive Access, triple-click the side button on Face ID devices or the Home button on iPhones with Touch ID, and it'll bring up the passcode prompt that lets the device switch back to the normal iPhone interface.

When I first set the phone up, I was worried I was missing something, that this solution could not be as good as it appeared. So I took the iPhone into an Apple Store and showed it to a support staffer. "What have you done?" he said, looking incredulously at my son's iPhone with its six dumb tiles. "This is a much better solution than Screen Time. I'm going to have to tell my colleagues about this." I told him it was Assistive Access. "We don't get trained on that," he admitted. "But this is great.

Jeremy's article goes into further detail, but everyone has the idea. It's worth looking at the show notes, or following the <https://grc.sc/dumb> GRC shortcut to the article, to see the picture of the phone. It looks so cool with the iPhone's screen occupied by a 2 x 3 grid of six big friendly application tiles. For anyone who may have an older iPhone available, or who may be unhappy with the iPhone options their children are currently using can explore this trick to see whether they'll be as happy with it as Jeremy's family clearly is. <https://grc.sc/dumb>

Listener Feedback

I need backpeddle on denying browser content pasting from the clipboard

Many of our listeners wrote to politely say the equivalent of "*Gibson, what are you smoking that could possibly allow you to imagine for a moment that denying the pasting of browser-copied clipboard data could ever be feasible?*" And every one of those who wrote is obviously correct. I, myself, am constantly marking and copying a blob of text from a web browser page and then transferring it to somewhere more permanent on my PC. I could not produce this podcast without that capability. So, indeed, flatly blocking that would never fly. And even putting up a warning each and every time would be so annoying that it would soon be disabled.

And if Windows were to try to determine whether the "pasting action" was user-driven versus script-driven, the bad guys would simply change their tactics to have the user first participate in the copying of the malicious command to their clipboard before pasting it outside the browser. So I apologize to Microsoft for ranting about their not fixing this, and I acknowledge that it is simply not fixable – which is probably the conclusion they reached long ago. My bad.

The true source of the problem is that Windows will obey powerful commands issued by its users through its user interface even when those users, who do not fully understand how Windows works, are just following some other entity's instructions. The Internet and the web browser is just one of many possible conduits for malicious instructions – eMail would do almost as well.

I still predict that our PCs are going to eventually evolve to sport their own local AI agent and the enforcement of the user's security will be one of any such agent's responsibilities. Several of

our listeners suggested that heuristic judgement about clipboard contents, such as the Brave browser is apparently employing, is likely the only workable solution. Having an AI watching over our activities – examining anything we copy to the system’s clipboard – would be the equivalent of a “super heuristic.”

Bob Sudduth

I've enjoyed listening to your discussions with Leo about AI. I recently started using Claude to help me pull old files off my church's website. One of the "issues" I ran into was that all of the pictures had names like 0e706c86-e5fe-4ccc-aeba-e9322130c24.jpg. There were several hundred of them and I dreaded looking at each one and renaming them. So I asked Claude if it could look at the picture and, based on the contents, rename the file. It built a python program and for 0.3 cents per picture, Claude perfectly renamed all the files with no prompting from me. It was awesome! Now I'm debating doing the same with the thousands of family pictures which have Date/Time or sequential numbers for their titles.

It’s not a stretch to imagine that at some point, perhaps with Apple’s much anticipated AI update this September, such photos will be automatically named on-the-fly by a resident image recognizing AI. But until then, and for archives such as Bob is facing, this is a terrific application for an agent.

Eric Goodwater

Hi Steve. With AI helping companies patch old zero-day vulnerabilities, how do you think this is affecting spyware vendors like NSO Group that depend on zero-days to operate? /Eric

I think it’s clear that over time—and perhaps not much time—the entire ecosystem surrounding flawed software is destined to change. There’s a very good chance that once AI reaches its full maturity, potential and integration into software creation, defective software will become a thing of the past. Insecure system design may still occur, but AI may also be able to spot mistakes there, too, like the recent Bitlocker bypass that was the result of poor design rather than a bug. All of the things we have come to know such as Pwn2Own competitions, HackerOne and other bug bounties, Zerodium, the NSO group and other resellers of vulnerability exploits, and even the necessity of having monthly patch cycles, are very likely to be impacted and eliminated. Anything that depended upon software being imperfect will simply wither away.

Ramiro Rela

<https://isaiprofitable.com/> *lovely page. didn't check the source of the data. listener for some years and listening to the archive from ep 1 when I get withdrawal syndrome from the current ones.*

It’s a neat looking page. AI “spend” is shown in red versus “revenue” which is shown in green. The page also shows a handful of companies that are “AI adjacent”, meaning Micron, AMD and Nvidia. They’re the only ones listed that “AI profitable” since they’re supplying the raw material needed to make AI possible. But as for the AI modelling providers themselves, none of this AI stuff has yet turned a profit for anyone on that side of the business.

Hallusquatting, GhostApproval & GitLost

From the moment AI emerged it's been abused. The world soon learned of, and we talked about so-called "Prompt Injection Attacks." It turns out that they, too, were in their infancy and attacks have continued to evolve with surprising speed. As I noted last week, the commercial AI industry has spent nearly all of its time making their AI offerings as capable as they knew how to while, from all available evidence, focusing far less on preventing the abuse of the power they were creating. That imbalance cannot stand. I am very certain that controlling AI abuse is going to turn out to be exceedingly difficult, perhaps even more so than creating the capability that requires the control.

Today, I want to report on three newly emerged means of abusing AI. They've been named Hallusquatting, GhostApproval and the one whose name I love the most: "GitLost."

ArsTechnica provided an explanation of the Hallusquatting attack under their headline "Hackers can use 9 of the most popular AI tools to assemble massive botnets" – you heard right.

In the brief history of AI security, prompt injection has quickly become the top threat. Large language models are inherently unable to distinguish between legitimate instructions provided by users and malicious ones sneaked into emails, source code, and other third-party content the models are processing. This makes it trivial to surreptitiously inject malicious commands that the LLM readily follows.

With no way to enforce this crucial boundary between trusted and untrusted sources, AI engine developers are left to erect elaborate guardrails designed to mitigate the damage rather than solve the root cause.

To date, most prompt injections have fallen into a class known as push, in which each potential victim is targeted. For example, the adversary injects malicious instructions into an individual email or calendar invitation. Because the injection must then be sent (or pushed) to each specific target, the scale of the attack is limited, hampering mass exploits that hit the Internet at large.

Meanwhile, pull-based attacks, in which an LLM actively seeks out the adversarial prompts planted on websites, remain limited. With no way to lure large numbers of LLMs to a malicious site, these sorts of attacks don't scale either.

Enter Hallusquatting: *Now, researchers have devised a pull-based attack that changes all that. This new attack which the researchers have named Hallusquatting has the potential to assemble massive botnets, perform large-scale DDoSes, and infect devices at scale, a first for prompt-injection attacks. The attack works against AI coding assistants and agents, including Cursor, Cursor CLI, Gemini CLI, Windsurf, GitHub Copilot, Cline, OpenClaw, ZeroClaw, and NanoClaw – all which are susceptible. In the normal course of performing day-to-day activities, these assistants and agents routinely pull code and other resources from repositories and registries.*

"Hallusquatting" is short for adversarial hallucination squatting. It is built on an LLM's inherent tendency to hallucinate the resource identifiers hosted in repositories and registries. It works against coding agents and assistants, which commonly access high-privilege command lines to

run code from third-party resources. By predicting the identifiers LLMs are most likely to hallucinate and then registering and seeding them with instructions to install reverse shells or other malicious wares, the attack can indiscriminately infect massive numbers of devices without having to target each one.

The researchers wrote in their paper: "The scalable property of the attack enables the attacker to compromise a large number of users with minimal effort by targeting popular resources, thereby maximizing the likelihood that the squatted resource will be retrieved. By exploiting integrated shells and terminals of agentic applications to run scripts and code, attackers can effectively 'infect' many independent agentic applications by embedding instructions to install reverse shells in the resources the attackers register."

With the ability to take control of distributed devices at scale, HalluSquatting has the potential to achieve various objectives not previously possible with prompt injections. Large ransomware campaigns and large botnets for use in DDoSes or cryptocurrency mining are two such examples.

The "squatting" part of the name is an invocation of "typosquatting," in which a domain, repository package, or other resource identifier closely mimics the name of a popular one in hopes of luring potential users to visit or install it. Typosquatting first gained widespread attention in 2016 when a college student uploaded 214 booby-trapped packages to the PyPI, RubyGems, and NPM repositories that closely mimicked names of legitimate packages. The result: The imposter code was executed more than 45,000 times on more than 17,000 separate domains, and more than half were given all-powerful administrative rights. Typosquatting attacks have flourished ever since.

So how does this work?

The starting point for HalluSquatting is the inability of LLMs to accurately identify the location of a resource specified by the user. When a developer, for instance, instructs a coding agent to clone a popular new repository, the LLM hallucinates its correct location up to 85 percent of the time. When cloning a trending "skill," a form of instruction, script, or resource that gives agents specialized capabilities and domain expertise, hallucinations can occur 100 percent of the time. HalluSquatting focuses on trending resources because they aren't included in the LLM training. They also receive large numbers of downloads over a short period of time.

The researchers say the inability of LLMs to provide the correct location is an inherent flaw that arises from training biases or from misinterpretations of instructions within the current context. That means when a user prompts the coding assistant to clone a repository or skill—in the form of, say, "clone repo name" or "install skill name"—the bot frequently navigates to the wrong location to retrieve it.

Not only are these hallucinations inevitable, but they also occur at the foundational level of all six of the major LLMs, including Gemini-2.5-flash, Gemini-2.5-pro, GPT-5.1, GPT-5.2, Sonnet-4.5, and Opus-4.5. Additionally, the most commonly provided incorrect locations that these LLMs hallucinate are easy to predict in advance. All six LLMs follow common patterns when resolving the repository or skill name in a prompt with its official name in a repository or skill repository.

LLMs follow various hallucination patterns. The one HalluSquatting exploits is described as being self-referential. All six models produce repo-name/repo-name slugs that treat a repository name as the owner. Exploiting the pattern requires no model probing.

Interestingly, the LLMs correctly resolve repositories published before 2019 with a low mean hallucination rate of just 0.9 percent. The same LLMs fabricate slugs for repositories published in 2025 with a mean hallucination rate of 92.4 percent.

Once an attacker has identified names that are most likely to be hallucinated, they search for ones that can be registered. Then they upload a repository or skill that mimics the trending resource. Buried inside the repository or skill is text inside a readme file or elsewhere. The text contains an instruction for the app to install a reverse shell on the LLM user's machine. Alternatively, the attacker can simply include the code required to install the shell. In either case, the coding assistants or agents use their access to command windows to comply.

In their paper the researchers wrote:

By exploiting integrated shells and terminals of agentic applications to run scripts and code, attackers can effectively "infect" many independent agentic applications by embedding instructions to install reverse shells in the resources the attackers register. Gaining access to distributed computational resources under attacker control opens the door to several high impact outcomes allowing attackers to achieve various goals. For example, having the ability to compromise LLM applications with terminals allows the attacker to scale the number of ransomware attacks on different networks to maximize financial gain. Alternatively, attackers can aggregate compromised machines into a botnet and use it for tasks that rely on substantial computing power, including large-scale cryptocurrency mining or performing distributed denial of service (DDoS) attacks against victims.

*HalluSquatting is already receiving interest from fellow AI security researchers not involved in the study. Michael Bargury, CTO of security firm Zenity, wrote in an email: "This is very cool research, and the threat is very real. Like typosquatting, it's a problem that's not going away. At the end of the day, it's about the level of agency we allow our agents. They *are* going to get fooled one way or another. That should be our assumption, and we should be resilient to that."*

Independent researcher Johann Rehberger wrote: "What's interesting is that it shows that LLM resource resolution can become an attack path and an attacker can first probe models to find high-probability hallucinated candidates (like repo names, skill identifiers, etc) to squat and wait for agents to resolve and use them. But the main point is that they found a cool technique to find resource names that are more likely by models to be used/confused with. And that could mean many agents falling for such attacks in the wild.

ArsTechnica concludes this reporting, writing:

AI tool makers frequently exaggerate the convenience and efficiency of their platforms. Marketers claim the platforms lighten workflows by automating and streamlining tedious tasks. They are much more reticent about the inherent flaws that can torpedo an entire project. Attacks like HalluSquatting provide a potent reminder that some of the efficiencies are exaggerated since, at the end of the day, users must double-check details such as the location for each resource incorporated into a project. It also provides a cautionary lesson on the unintended and potentially dire outcomes that can result when people rely too heavily on AI assistants.

So, just to be sure that everyone understands this: Since AI doesn't know how to say "I don't

know”, it will invent – i.e. hallucinate – the name of something it doesn’t know. Attackers have figured out that the names AI models will invent are predictable. So much as with typosquatting, the attackers register a resource that’s highly likely to be hallucinated and there they plant malicious prompting commands which the AI, not knowing any better, will dutifully execute.

Before we leave this I wanted to give a shout-out to Ben Nassi, one of the research authors named in this paper. Ben has been very prolific for many years, inventing creative exploits often finding new ways to exfiltrate information in unlikely situations – like changing a system’s power consumption to slightly change the sound being made by its switching power supply. And who could forget the vibrating plant leaf or the party balloon picking up the sound of the room’s voices? It’s nice to see you’re still at it, Ben! Okay, on to the next new AI exploit:

The guys at Wiz Security titled their write-up of this “GhostApproval: A Trust Boundary Gap in AI Coding Assistants” and then teased their research with the summary: “Uncovering a category-level blind spot in modern AI coding assistants, and why the Human-in-the-Loop safety model fails against this classic threat. They explain:

The value of AI coding assistants is simple and straightforward: the agent proposes an action, then you approve. Before any file is modified, a confirmation dialog appears: the Human-in-the-Loop safety net that keeps you in control. But what if the controls you see aren’t the controls you’re actually operating?

Symbolic links have been a security headache since the early days of Unix. From /tmp race conditions to privilege escalation exploits, symlinks have a long history of bypassing security boundaries by making one path silently resolve to another. It’s a well-documented attack primitive dating back decades. So what happens when you apply this classic trick to AI coding assistants?

We discovered GhostApproval, a systematic vulnerability pattern affecting 6 of the top AI coding assistants: Amazon Q Developer, Anthropic Claude Code, Augment, Cursor, Google Antigravity, and Windsurf. In each case, a malicious repository can trick the agent into accessing arbitrary files outside the workspace sandbox, potentially achieving remote code execution on the developer’s machine.

The technical primitive of symlink following is well-known. What we found, however, goes further: in several cases, the agent’s internal reasoning explicitly recognizes the dangerous target, yet the confirmation prompt shown to the user conceals this information entirely. This is a UI misrepresentation of critical information – layered on top of the symlink vulnerability. The user approves what they believe is a harmless local edit; the agent writes to a sensitive file outside of the project workspace.

We reported these findings to all 6 vendors. Three fixed the issue promptly: AWS, Cursor and Google. Two acknowledged its receipt but went silent. One provided a reasoned rejection, calling it “outside our threat model”, a position we explore later in this post.

The discovery started the way many do: with a simple question. While using an AI coding tool, we had the classic security researcher’s intuition: “what happens if I use a symlink?”

Symlinks have been exploited for decades – in race conditions, in package managers, in container escapes. Any time a tool writes to a user-controlled path without resolving it first, symlinks become a weapon. Would AI agents, with their ability to read and write files autonomously, fall for the same trick?

We were surprised when it worked. The agent happily followed a symlink pointing outside the workspace and wrote to the target file. No warning, no path resolution, no sandbox enforcement. That first success raised a broader question. These AI coding assistants are all relatively new, shipping rapidly to capture a hot market. If one had this gap, others might too. We decided to test systematically.

The results confirmed the pattern. Across six major tools – spanning products from Amazon, Anthropic, Augment, Cursor, Google, and Windsurf – we found variations of the same fundamental flaw. This wasn't about one vendor's mistake. It was a category-level blind spot across AI coding tools.

That's all the time I want to spend on this since it's not rocket science and since all six vendors have now fixed it. But it serves as a good example of the fact that the reimplementing of old solutions in a new context may force us to go back and re-fix long-resolved problems that originally resulted due to poor design decisions. Yes, symbolic links are super powerful. But they can also be super dangerous.

And this brings us to my favorite-named vulnerability: "GitLost" The researchers at Noma Security explained under their headline: *"GitLost: How We Tricked GitHub's AI Agent into Leaking Private Repos"*

GitHub recently launched GitHub Agentic Workflows, pairing GitHub Actions (GitHub's automation system for running tasks in response to repository events) with an AI agent backed by Claude or GitHub Copilot. GitHub Agentic Workflows allow teams to write their GitHub workflows in plain Markdown, and the GitHub agent reads issues, calls tools, and responds on its own.

As a vulnerability researcher with a security development background, one of the first questions that came to mind after this launch was fundamental and straightforward: What will happen when the GitHub agent reads something it should not trust?

The answer is a textbook indirect prompt-injection attack, the kind of attack that quietly sends private data to anyone on the internet. Prompt injection is a class of attack in which an adversary hides malicious instructions inside the content read by an AI agent. That content causes the agent to follow those hidden instructions instead of the ones its operator intended.

What are GitHub Agentic Workflows?

GitHub Agentic Workflows let teams automate their interactions with code repositories using natural language. Workflows live in Markdown (.md) files, are compiled into YAML (a common configuration file format) Actions files with the .yml extension, and run with the help of an AI agent with configurable permissions. The GitHub agent can read issues, call tools, and access other repositories within an organization.

GitLost Vulnerability Overview:

The root cause of the GitLost vulnerability is, by now, a familiar one in agentic AI systems: prompt injection. In most agentic prompt injection attacks, the agent treats the wrong content as a trusted source of instructions and allows itself to be misdirected or misused. This happens when the system fails to maintain a strict trust boundary between system-level directives and untrusted user data. In this specific case, any malicious actor can create a GitHub Issue and, in the issue body, hide commands in plain English that GitHub's agent will follow.

The vulnerable Github Agentic Workflow Noma Labs discovered was configured to:

- *Trigger the workflow on issues.assigned events in GitHub*
- *Read the issue Title and Body*
- *Post a comment in response using the add-comment tool*
- *Run with read access to other repositories (public and private) in the organization*

To exploit this vulnerability, the attacker needed no coding skills, access, or credentials. All that was needed was to open an issue in a public repository belonging to an organization that uses GitHub's Agentic Workflow setup ... and wait.

Skipping their specific attack exploit descriptions we arrive at their conclusion which explains why today's AI keeps having these problems over and over. Under "*Why this matters*" they write:

GitLost perfectly illustrates one of the fundamental security challenges every organization faces with agentic AI systems. The agent's context window is also its attack surface.

*Any content the agent reads, whether issues, pull requests, comments, or files, can be weaponized if the agent treats that content as **instructional** input – which, by design, they all do.*

Traditional security models assume that trust boundaries are enforced by code. In agentic systems, trust boundaries are partly enforced by the model's behavior, and models are inherently instruction-following. Prompt injection attacks have become, to agentic AI, what SQL injections were to web applications: a systematic, category-wide vulnerability class that requires the same systematic strategies and defenses.

We've seen this fundamental security trouble several times in many other contexts long before AI was on the scene. Whenever command and control share the same channel as, and are mixed-in with data, and when an attacker can control the data, it may be possible for a clever attacker to cause the receiving system to mistake their data for the system's command and control ... which is never good. Today's AI operates this way. It feels ad hoc, extremely abuse prone and insecure. As such, it creates a fundamental and outstanding problem that the AI industry needs to solve.

